SeniorShield: Backend-Only Specification for Replit

Overview

This specification is for building the **Backend API** that your mobile app (already built in Replit) will connect to. The backend will handle authentication, data persistence, billing, integrations, and all business logic.

Tech Stack:

- Framework: Node.js + Express
- Database: PostgreSQL
- Authentication: JWT (JSON Web Tokens)
- Payment: Stripe API
- Voice: OpenAI Realtime API (already integrated in mobile app)
- Hosting: AWS EC2, RDS, S3

Timeline: 6-8 weeks

---

1. Architecture Overview

Plain Text

```
┌──────────────────────────────────────────────────────────────┐
│ YOUR MOBILE APP (Already Built in Replit)                    │
│ - React Native                                               │
│ - Voice orb, scam analyzer, settings, etc.                   │
│ - Makes API calls to backend                                 │
└──────────────────────────────────────────────────────────────┘
                    │
                    │
                    │ HTTP/HTTPS API Calls
                    ↓
┌──────────────────────────────────────────────────────────────┐
│ BACKEND API (To Build in Replit)                             │
│ - Node.js + Express                                          │
│ - 100+ endpoints                                             │
│ - Authentication, billing, integrations                      │
└──────────────────────────────────────────────────────────────┘
                    │
                    │
                    │ SQL Queries
```

```
                    ↓
┌──────────────────────────────────────────────────────────┐
│ DATABASE (PostgreSQL)                                    │
│ - 15 tables                                              │
│ - User data, subscriptions, scam history, etc.          │
└──────────────────────────────────────────────────────────┘

FUTURE:
┌──────────────────────────────────────────────────────────┐
│ ADMIN PANEL (React Web - To Build Later)                 │
│ - Dashboard, user management, revenue tracking           │
│ - Also calls same backend API                            │
└──────────────────────────────────────────────────────────┘
```

---

2. Database Schema (15 Tables)

Core User Tables

TABLE: users

SQL

```sql
CREATE TABLE users (
  user_id UUID PRIMARY KEY,
  email VARCHAR(255) UNIQUE NOT NULL,
  password_hash VARCHAR(255) NOT NULL,
  account_type VARCHAR(50) NOT NULL, -- B2C, B2B_TELECOM, B2B_INSURANCE, B2B_FA
  subscription_type VARCHAR(50) NOT NULL, -- FREE, PREMIUM, FAMILY
  subscription_source VARCHAR(50), -- STRIPE, VERIZON, AT&T, T-MOBILE, MEDICARE,
  subscription_id VARCHAR(255), -- External subscription ID from provider
  created_at TIMESTAMP DEFAULT CURRENT_TIMESTAMP,
  updated_at TIMESTAMP DEFAULT CURRENT_TIMESTAMP,
  last_login TIMESTAMP
);
```

TABLE: user_profiles

SQL

```sql
CREATE TABLE user_profiles (
  profile_id UUID PRIMARY KEY,
  user_id UUID UNIQUE NOT NULL REFERENCES users(user_id),
  first_name VARCHAR(100),
  last_name VARCHAR(100),
  phone_number VARCHAR(20),
```

```
  date_of_birth DATE,
  hearing_loss_level VARCHAR(50), -- NONE, MILD, MODERATE, SEVERE
  tech_comfort_level VARCHAR(50), -- BEGINNER, INTERMEDIATE, ADVANCED
  created_at TIMESTAMP DEFAULT CURRENT_TIMESTAMP,
  updated_at TIMESTAMP DEFAULT CURRENT_TIMESTAMP
);
```

TABLE: user_settings

SQL

```sql
CREATE TABLE user_settings (
  setting_id UUID PRIMARY KEY,
  user_id UUID UNIQUE NOT NULL REFERENCES users(user_id),
  color_scheme VARCHAR(50), -- LIGHT, DARK, WARM, COOL
  font_size VARCHAR(50), -- SMALL, NORMAL, LARGE, EXTRA_LARGE
  font_family VARCHAR(50), -- SANS_SERIF, SERIF
  line_height VARCHAR(50), -- COMPACT, NORMAL, SPACIOUS
  letter_spacing VARCHAR(50), -- NORMAL, WIDE
  high_contrast_enabled BOOLEAN DEFAULT FALSE,
  captions_enabled BOOLEAN DEFAULT TRUE,
  voice_gender VARCHAR(50), -- FEMALE, MALE
  voice_speed DECIMAL(2,1), -- 0.5 to 1.5
  voice_volume INTEGER, -- 0 to 100
  hearing_aid_connected BOOLEAN DEFAULT FALSE,
  hearing_aid_model VARCHAR(100),
  created_at TIMESTAMP DEFAULT CURRENT_TIMESTAMP,
  updated_at TIMESTAMP DEFAULT CURRENT_TIMESTAMP
);
```

Voice & Scam History Tables

TABLE: voice_requests

SQL

```sql
CREATE TABLE voice_requests (
  request_id UUID PRIMARY KEY,
  user_id UUID NOT NULL REFERENCES users(user_id),
  request_text TEXT NOT NULL,
  response_text TEXT NOT NULL,
  voice_file_path VARCHAR(500), -- S3 URL
  duration_seconds INTEGER,
  success BOOLEAN DEFAULT TRUE,
  error_message TEXT,
  user_rating INTEGER, -- 1-5 stars
```

```
  created_at TIMESTAMP DEFAULT CURRENT_TIMESTAMP
);
```

TABLE: scam_analyses

```sql
CREATE TABLE scam_analyses (
  analysis_id UUID PRIMARY KEY,
  user_id UUID NOT NULL REFERENCES users(user_id),
  input_text TEXT NOT NULL,
  risk_score INTEGER, -- 0-100
  risk_level VARCHAR(50), -- SAFE, LOW, MEDIUM, HIGH, CRITICAL
  detected_patterns JSONB, -- Array of pattern names
  explanation TEXT,
  recommended_action TEXT,
  user_reported_scam BOOLEAN DEFAULT FALSE,
  family_notified BOOLEAN DEFAULT FALSE,
  created_at TIMESTAMP DEFAULT CURRENT_TIMESTAMP
);
```

TABLE: scam_library

```sql
CREATE TABLE scam_library (
  pattern_id UUID PRIMARY KEY,
  pattern_name VARCHAR(100) NOT NULL,
  keywords JSONB, -- Array of keywords
  description TEXT,
  accuracy INTEGER, -- 0-100
  false_positive_rate INTEGER, -- 0-100
  created_at TIMESTAMP DEFAULT CURRENT_TIMESTAMP,
  updated_at TIMESTAMP DEFAULT CURRENT_TIMESTAMP
);
```

Contacts & Family Tables

TABLE: contacts

```sql
CREATE TABLE contacts (
  contact_id UUID PRIMARY KEY,
  user_id UUID NOT NULL REFERENCES users(user_id),
  contact_name VARCHAR(100) NOT NULL,
```

```
  phone_number VARCHAR(20),
  email VARCHAR(255),
  category VARCHAR(50), -- FAMILY, FRIEND, DOCTOR, OTHER
  favorite_task VARCHAR(100),
  usage_count INTEGER DEFAULT 0,
  created_at TIMESTAMP DEFAULT CURRENT_TIMESTAMP,
  updated_at TIMESTAMP DEFAULT CURRENT_TIMESTAMP
);
```

TABLE: family_members

SQL

```
CREATE TABLE family_members (
  family_id UUID PRIMARY KEY,
  user_id UUID NOT NULL REFERENCES users(user_id),
  family_email VARCHAR(255) NOT NULL,
  family_name VARCHAR(100),
  relationship VARCHAR(50), -- CHILD, SIBLING, SPOUSE, CAREGIVER, OTHER
  status VARCHAR(50), -- PENDING, ACTIVE, INACTIVE
  created_at TIMESTAMP DEFAULT CURRENT_TIMESTAMP,
  updated_at TIMESTAMP DEFAULT CURRENT_TIMESTAMP
);
```

TABLE: family_alerts

SQL

```
CREATE TABLE family_alerts (
  alert_id UUID PRIMARY KEY,
  user_id UUID NOT NULL REFERENCES users(user_id),
  family_id UUID NOT NULL REFERENCES family_members(family_id),
  alert_type VARCHAR(50), -- SCAM_DETECTED, HELP_NEEDED, WEEKLY_SUMMARY, EMERGE
  alert_message TEXT,
  read BOOLEAN DEFAULT FALSE,
  created_at TIMESTAMP DEFAULT CURRENT_TIMESTAMP
);
```

Subscription & Billing Tables

TABLE: subscriptions

SQL

```
CREATE TABLE subscriptions (
  subscription_id UUID PRIMARY KEY,
```

```
  user_id UUID NOT NULL REFERENCES users(user_id),
  subscription_type VARCHAR(50), -- FREE, PREMIUM, FAMILY
  subscription_source VARCHAR(50), -- STRIPE, VERIZON, AT&T, T-MOBILE, MEDICARE,
  external_subscription_id VARCHAR(255), -- ID from provider
  status VARCHAR(50), -- ACTIVE, CANCELLED, SUSPENDED
  current_period_start DATE,
  current_period_end DATE,
  cancel_at_period_end BOOLEAN DEFAULT FALSE,
  created_at TIMESTAMP DEFAULT CURRENT_TIMESTAMP,
  updated_at TIMESTAMP DEFAULT CURRENT_TIMESTAMP
);
```

Partner Integration Tables

TABLE: telecom_accounts

SQL

```sql
CREATE TABLE telecom_accounts (
  telecom_id UUID PRIMARY KEY,
  user_id UUID NOT NULL REFERENCES users(user_id),
  carrier VARCHAR(50), -- VERIZON, AT&T, T-MOBILE
  carrier_user_id VARCHAR(255), -- External ID from carrier
  carrier_phone VARCHAR(20),
  carrier_auth_token VARCHAR(500), -- Encrypted
  subscription_status VARCHAR(50), -- ACTIVE, CANCELLED, SUSPENDED
  created_at TIMESTAMP DEFAULT CURRENT_TIMESTAMP,
  updated_at TIMESTAMP DEFAULT CURRENT_TIMESTAMP
);
```

TABLE: insurance_accounts

SQL

```sql
CREATE TABLE insurance_accounts (
  insurance_id UUID PRIMARY KEY,
  user_id UUID NOT NULL REFERENCES users(user_id),
  insurance_provider VARCHAR(100), -- UNITEDHEALTHCARE, HUMANA, ANTHEM, etc.
  member_id VARCHAR(255), -- External ID from insurance
  member_dob DATE,
  insurance_auth_token VARCHAR(500), -- Encrypted
  subscription_status VARCHAR(50), -- ACTIVE, CANCELLED, SUSPENDED
  created_at TIMESTAMP DEFAULT CURRENT_TIMESTAMP,
  updated_at TIMESTAMP DEFAULT CURRENT_TIMESTAMP
);
```

TABLE: facility_accounts

```sql
CREATE TABLE facility_accounts (
  facility_id UUID PRIMARY KEY,
  facility_name VARCHAR(255) NOT NULL,
  facility_type VARCHAR(50), -- SENIOR_CENTER, SENIOR_LIVING, ASSISTED_LIVING
  address VARCHAR(255),
  city VARCHAR(100),
  state VARCHAR(50),
  zip VARCHAR(10),
  phone VARCHAR(20),
  email VARCHAR(255),
  admin_user_id UUID NOT NULL REFERENCES users(user_id),
  api_key VARCHAR(500), -- Encrypted
  facility_code VARCHAR(50) UNIQUE,
  subscription_status VARCHAR(50), -- ACTIVE, CANCELLED, SUSPENDED
  created_at TIMESTAMP DEFAULT CURRENT_TIMESTAMP,
  updated_at TIMESTAMP DEFAULT CURRENT_TIMESTAMP
);
```

TABLE: facility_residents

```sql
CREATE TABLE facility_residents (
  resident_id UUID PRIMARY KEY,
  facility_id UUID NOT NULL REFERENCES facility_accounts(facility_id),
  user_id UUID NOT NULL REFERENCES users(user_id),
  resident_name VARCHAR(100),
  joined_at TIMESTAMP,
  status VARCHAR(50), -- ACTIVE, INACTIVE, DEPARTED
  created_at TIMESTAMP DEFAULT CURRENT_TIMESTAMP,
  updated_at TIMESTAMP DEFAULT CURRENT_TIMESTAMP
);
```

Admin & Logging Tables

TABLE: admin_users

```sql
CREATE TABLE admin_users (
  admin_id UUID PRIMARY KEY,
  email VARCHAR(255) UNIQUE NOT NULL,
```

```
  password_hash VARCHAR(255) NOT NULL,
  role VARCHAR(50), -- SUPER_ADMIN, FINANCE, SALES, SUPPORT, ANALYST
  permissions JSONB, -- JSON object with permissions
  created_at TIMESTAMP DEFAULT CURRENT_TIMESTAMP,
  updated_at TIMESTAMP DEFAULT CURRENT_TIMESTAMP,
  last_login TIMESTAMP
);
```

TABLE: admin_activity_log

SQL

```sql
CREATE TABLE admin_activity_log (
  log_id UUID PRIMARY KEY,
  admin_id UUID NOT NULL REFERENCES admin_users(admin_id),
  action VARCHAR(50), -- CREATE, UPDATE, DELETE, VIEW
  resource_type VARCHAR(50), -- USER, FACILITY, TELECOM, INSURANCE
  resource_id VARCHAR(255),
  changes JSONB,
  timestamp TIMESTAMP DEFAULT CURRENT_TIMESTAMP
);
```

TABLE: analytics_events

SQL

```sql
CREATE TABLE analytics_events (
  event_id UUID PRIMARY KEY,
  user_id UUID REFERENCES users(user_id),
  event_type VARCHAR(50), -- VOICE_REQUEST, SCAM_ANALYSIS, FAMILY_ALERT, SUBSCR
  event_data JSONB,
  created_at TIMESTAMP DEFAULT CURRENT_TIMESTAMP
);
```

TABLE: error_logs

SQL

```sql
CREATE TABLE error_logs (
  log_id UUID PRIMARY KEY,
  user_id UUID REFERENCES users(user_id),
  error_message TEXT NOT NULL,
  error_stack TEXT,
  endpoint VARCHAR(255),
  status_code INTEGER,
```

```
  created_at TIMESTAMP DEFAULT CURRENT_TIMESTAMP
);
```

---

3. API Endpoints (100+)

Authentication Endpoints (6)

Plain Text

```
POST /api/auth/signup
Request: { email, password, first_name, last_name }
Response: { user_id, token, subscription_type }

POST /api/auth/login
Request: { email, password }
Response: { user_id, token, subscription_type }

POST /api/auth/logout
Request: { token }
Response: { success: true }

POST /api/auth/refresh-token
Request: { refresh_token }
Response: { token, refresh_token }

POST /api/auth/password-reset
Request: { email }
Response: { success: true, message: "Reset email sent" }

POST /api/auth/verify-email
Request: { email, verification_code }
Response: { success: true }
```

User Profile Endpoints (6)

Plain Text

```
GET /api/user/profile
Headers: Authorization: Bearer {token}
Response: { user_id, email, first_name, last_name, phone, dob, hearing_loss, te

PUT /api/user/profile
Headers: Authorization: Bearer {token}
Request: { first_name, last_name, phone, dob, hearing_loss, tech_comfort }
```

```
Response: { success: true, profile }

GET /api/user/settings
Headers: Authorization: Bearer {token}
Response: { color_scheme, font_size, voice_gender, voice_speed, voice_volume, .

PUT /api/user/settings
Headers: Authorization: Bearer {token}
Request: { color_scheme, font_size, voice_gender, voice_speed, voice_volume, ..
Response: { success: true, settings }

POST /api/user/password/change
Headers: Authorization: Bearer {token}
Request: { current_password, new_password }
Response: { success: true }

POST /api/user/account/delete
Headers: Authorization: Bearer {token}
Request: { password }
Response: { success: true, message: "Account deleted" }
```

Voice Assistance Endpoints (6)

Plain Text

```
POST /api/voice/request
Headers: Authorization: Bearer {token}
Request: { request_text, voice_file_path (optional) }
Response: { request_id, response_text, voice_file_path, duration_seconds }

GET /api/voice/history
Headers: Authorization: Bearer {token}
Query: ?limit=20&offset=0
Response: { requests: [...], total_count }

GET /api/voice/history/:request_id
Headers: Authorization: Bearer {token}
Response: { request_id, request_text, response_text, created_at, user_rating }

POST /api/voice/feedback
Headers: Authorization: Bearer {token}
Request: { request_id, rating (1-5), feedback_text }
Response: { success: true }

GET /api/voice/preferences
Headers: Authorization: Bearer {token}
Response: { voice_gender, voice_speed, voice_volume, hearing_aid_connected }
```

```
PUT /api/voice/preferences
Headers: Authorization: Bearer {token}
Request: { voice_gender, voice_speed, voice_volume }
Response: { success: true, preferences }
```

Scam Detection Endpoints (6)

Plain Text

```
POST /api/scam/analyze
Headers: Authorization: Bearer {token}
Request: { input_text }
Response: { analysis_id, risk_score, risk_level, detected_patterns, explanation

GET /api/scam/history
Headers: Authorization: Bearer {token}
Query: ?limit=20&offset=0
Response: { analyses: [...], total_count }

GET /api/scam/history/:analysis_id
Headers: Authorization: Bearer {token}
Response: { analysis_id, input_text, risk_score, risk_level, explanation, creat

POST /api/scam/report
Headers: Authorization: Bearer {token}
Request: { analysis_id, report_to_family: true/false }
Response: { success: true, family_notified: true/false }

GET /api/scam/library
Headers: Authorization: Bearer {token}
Response: { patterns: [...], total_patterns }

POST /api/scam/library/update
Headers: Authorization: Bearer {token}, X-Admin-Token: {admin_token}
Request: { pattern_name, keywords, description, accuracy }
Response: { success: true, pattern_id }
```

Family Management Endpoints (8)

Plain Text

```
POST /api/family/add
Headers: Authorization: Bearer {token}
Request: { family_email, family_name, relationship }
Response: { family_id, status: "PENDING" }
```

```
GET /api/family/members
Headers: Authorization: Bearer {token}
Response: { members: [...], total_count }

GET /api/family/members/:family_id
Headers: Authorization: Bearer {token}
Response: { family_id, family_email, family_name, relationship, status }

PUT /api/family/members/:family_id
Headers: Authorization: Bearer {token}
Request: { family_name, relationship }
Response: { success: true, member }

DELETE /api/family/members/:family_id
Headers: Authorization: Bearer {token}
Response: { success: true }

POST /api/family/alert
Headers: Authorization: Bearer {token}
Request: { alert_type, alert_message }
Response: { alert_id, created_at }

GET /api/family/alerts
Headers: Authorization: Bearer {token}
Query: ?limit=20&offset=0
Response: { alerts: [...], total_count }

POST /api/family/message
Headers: Authorization: Bearer {token}
Request: { family_id, message }
Response: { success: true, message_id }
```

Contacts Endpoints (6)

Plain Text

```
POST /api/contacts/add
Headers: Authorization: Bearer {token}
Request: { contact_name, phone_number, email, category, favorite_task }
Response: { contact_id, created_at }

GET /api/contacts/list
Headers: Authorization: Bearer {token}
Query: ?limit=50&offset=0
Response: { contacts: [...], total_count }
```

```
GET /api/contacts/:contact_id
Headers: Authorization: Bearer {token}
Response: { contact_id, contact_name, phone_number, email, category, favorite_t

PUT /api/contacts/:contact_id
Headers: Authorization: Bearer {token}
Request: { contact_name, phone_number, email, category, favorite_task }
Response: { success: true, contact }

DELETE /api/contacts/:contact_id
Headers: Authorization: Bearer {token}
Response: { success: true }

GET /api/contacts/suggestions
Headers: Authorization: Bearer {token}
Response: { suggestions: [...] }
```

Subscription & Billing Endpoints (8)

Plain Text

```
POST /api/billing/checkout
Headers: Authorization: Bearer {token}
Request: { subscription_type: "PREMIUM" or "FAMILY", billing_cycle: "monthly" o
Response: { checkout_url, session_id }

GET /api/billing/subscription
Headers: Authorization: Bearer {token}
Response: { subscription_id, subscription_type, subscription_source, status, cu

PUT /api/billing/subscription
Headers: Authorization: Bearer {token}
Request: { subscription_type: "PREMIUM" or "FAMILY" }
Response: { success: true, subscription }

DELETE /api/billing/subscription
Headers: Authorization: Bearer {token}
Response: { success: true, message: "Subscription cancelled" }

GET /api/billing/invoices
Headers: Authorization: Bearer {token}
Query: ?limit=20&offset=0
Response: { invoices: [...], total_count }

PUT /api/billing/payment-method
Headers: Authorization: Bearer {token}
Request: { payment_method_id }
```

```
Response: { success: true }

POST /api/billing/webhook
Request: { stripe_event }
Response: { received: true }

GET /api/billing/trial-status
Headers: Authorization: Bearer {token}
Response: { trial_active: true/false, trial_days_remaining: 7 }
```

Telecom Integration Endpoints (6)

Plain Text

```
POST /api/telecom/verizon/oauth/callback
Request: { code, state }
Response: { success: true, subscription_upgraded: true }

POST /api/telecom/att/oauth/callback
Request: { code, state }
Response: { success: true, subscription_upgraded: true }

POST /api/telecom/tmobile/oauth/callback
Request: { code, state }
Response: { success: true, subscription_upgraded: true }

GET /api/telecom/status
Headers: Authorization: Bearer {token}
Response: { carrier: "VERIZON", status: "ACTIVE", phone: "+1-555-0123" }

POST /api/telecom/disconnect
Headers: Authorization: Bearer {token}
Request: { carrier }
Response: { success: true }

POST /api/telecom/billing/webhook
Request: { carrier_event }
Response: { received: true }
```

Insurance Integration Endpoints (6)

Plain Text

```
POST /api/insurance/medicare/oauth/callback
Request: { code, state }
Response: { success: true, subscription_upgraded: true }
```

```
GET /api/insurance/status
Headers: Authorization: Bearer {token}
Response: { insurance_provider: "HUMANA", status: "ACTIVE", member_id: "123456"

POST /api/insurance/disconnect
Headers: Authorization: Bearer {token}
Request: { insurance_provider }
Response: { success: true }

POST /api/insurance/billing/webhook
Request: { insurance_event }
Response: { received: true }

GET /api/insurance/plans
Response: { plans: [...] }

POST /api/insurance/verify-member
Request: { member_id, dob }
Response: { valid: true/false }
```

Facility Management Endpoints (10)

Plain Text

```
POST /api/facilities/register
Request: { facility_name, facility_type, address, city, state, zip, phone, emai
Response: { facility_id, facility_code, api_key }

GET /api/facilities/:facility_id
Headers: Authorization: Bearer {token}
Response: { facility_id, facility_name, facility_type, address, admin_user_id,

PUT /api/facilities/:facility_id
Headers: Authorization: Bearer {token}
Request: { facility_name, address, city, state, zip, phone, email }
Response: { success: true, facility }

DELETE /api/facilities/:facility_id
Headers: Authorization: Bearer {token}
Response: { success: true }

POST /api/facilities/:facility_id/residents/add
Headers: Authorization: Bearer {token}
Request: { resident_email, resident_name }
Response: { resident_id, status: "PENDING" }
```

```
GET /api/facilities/:facility_id/residents
Headers: Authorization: Bearer {token}
Query: ?limit=50&offset=0
Response: { residents: [...], total_count }

GET /api/facilities/:facility_id/dashboard
Headers: Authorization: Bearer {token}
Response: { total_residents, active_residents, scams_detected, alerts_sent }

GET /api/facilities/:facility_id/alerts
Headers: Authorization: Bearer {token}
Query: ?limit=20&offset=0
Response: { alerts: [...], total_count }

POST /api/facilities/billing/webhook
Request: { facility_event }
Response: { received: true }

GET /api/facilities/:facility_id/analytics
Headers: Authorization: Bearer {token}
Response: { engagement_stats, scam_stats, usage_trends }
```

Emergency Endpoints (2)

Plain Text

```
POST /api/emergency/sos
Headers: Authorization: Bearer {token}
Request: { location (optional) }
Response: { success: true, family_notified: true, emergency_id }

POST /api/emergency/notify-family
Headers: Authorization: Bearer {token}
Request: { message }
Response: { success: true, notifications_sent: 3 }
```

Admin Endpoints (20+)

Plain Text

```
POST /api/admin/login
Request: { email, password }
Response: { admin_id, token, role }

GET /api/admin/dashboard/metrics
Headers: Authorization: Bearer {admin_token}
```

```
Response: { total_users, mau, dau, mrr, arr, churn_rate, scams_detected }

GET /api/admin/users
Headers: Authorization: Bearer {admin_token}
Query: ?limit=50&offset=0&search=&sort_by=created_at
Response: { users: [...], total_count }

GET /api/admin/users/:user_id
Headers: Authorization: Bearer {admin_token}
Response: { user_id, email, subscription_type, created_at, last_login, voice_re

PUT /api/admin/users/:user_id
Headers: Authorization: Bearer {admin_token}
Request: { subscription_type, status }
Response: { success: true, user }

DELETE /api/admin/users/:user_id
Headers: Authorization: Bearer {admin_token}
Response: { success: true }

GET /api/admin/facilities
Headers: Authorization: Bearer {admin_token}
Query: ?limit=50&offset=0&search=&sort_by=created_at
Response: { facilities: [...], total_count }

GET /api/admin/telecom/partners
Headers: Authorization: Bearer {admin_token}
Response: { partners: [{ carrier: "VERIZON", users: 5000, mrr: 50000 }] }

GET /api/admin/insurance/partners
Headers: Authorization: Bearer {admin_token}
Response: { partners: [{ provider: "HUMANA", users: 10000, mrr: 100000 }] }

GET /api/admin/financial/revenue
Headers: Authorization: Bearer {admin_token}
Query: ?start_date=2024-01-01&end_date=2024-12-31
Response: { total_revenue, by_channel: {...}, by_month: [...] }

GET /api/admin/financial/invoices
Headers: Authorization: Bearer {admin_token}
Query: ?limit=50&offset=0&status=PAID
Response: { invoices: [...], total_count }

GET /api/admin/support/tickets
Headers: Authorization: Bearer {admin_token}
Query: ?limit=50&offset=0&status=OPEN
Response: { tickets: [...], total_count }
```

```
GET /api/admin/analytics/users
Headers: Authorization: Bearer {admin_token}
Response: { total_users, by_channel, by_subscription_type, growth_rate }

GET /api/admin/analytics/engagement
Headers: Authorization: Bearer {admin_token}
Response: { dau, mau, avg_session_duration, voice_requests_per_user }

GET /api/admin/analytics/scams
Headers: Authorization: Bearer {admin_token}
Response: { total_scams_detected, scams_reported, scams_prevented_value, detect

GET /api/admin/analytics/churn
Headers: Authorization: Bearer {admin_token}
Response: { monthly_churn_rate, churn_by_channel, churn_reasons }

GET /api/admin/settings
Headers: Authorization: Bearer {admin_token}
Response: { company_settings, integrations, feature_flags }

PUT /api/admin/settings
Headers: Authorization: Bearer {admin_token}
Request: { settings_object }
Response: { success: true }

POST /api/admin/staff/add
Headers: Authorization: Bearer {admin_token}
Request: { email, role }
Response: { admin_id, created_at }

GET /api/admin/staff
Headers: Authorization: Bearer {admin_token}
Response: { staff: [...], total_count }
```

Analytics Endpoints (4)

Plain Text

```
GET /api/analytics/events
Headers: Authorization: Bearer {admin_token}
Query: ?event_type=VOICE_REQUEST&limit=100
Response: { events: [...], total_count }

GET /api/analytics/users
Headers: Authorization: Bearer {admin_token}
Response: { total_users, new_users_today, new_users_this_month }
```

```
GET /api/analytics/engagement
Headers: Authorization: Bearer {admin_token}
Response: { dau, mau, avg_session_duration, voice_requests_per_user }

GET /api/analytics/errors
Headers: Authorization: Bearer {admin_token}
Query: ?limit=50&offset=0&sort_by=created_at
Response: { errors: [...], total_count }
```

Help & Support Endpoints (4)

Plain Text

```
GET /api/help/faq
Response: { faqs: [...] }

GET /api/help/tutorials
Response: { tutorials: [...] }

POST /api/support/ticket
Headers: Authorization: Bearer {token}
Request: { subject, description, category }
Response: { ticket_id, status: "OPEN" }

GET /api/support/ticket/:ticket_id
Headers: Authorization: Bearer {token}
Response: { ticket_id, subject, description, status, created_at, updated_at }
```

---

4. Authentication & Security

JWT Authentication Flow

Plain Text

```
1. User signs up: POST /api/auth/signup
   - Create user in database
   - Hash password with bcrypt
   - Generate JWT token
   - Return token to mobile app

2. Mobile app stores token in secure storage
   - iOS: Keychain
   - Android: Keystore
```

```
3. Mobile app makes API calls with token
   - Headers: Authorization: Bearer {token}

4. Backend validates token on every request
   - Verify JWT signature
   - Check token expiration
   - Extract user_id from token

5. Token expires after 24 hours
   - User can refresh token with refresh_token
   - Or user logs in again
```

Password Security

Plain Text

```
- Passwords hashed with bcrypt (cost factor: 12)
- Never store plain text passwords
- Password reset via email with temporary token
- Temporary token expires after 1 hour
```

Data Encryption

Plain Text

```
- Sensitive data encrypted with AES-256
  - Telecom auth tokens
  - Insurance auth tokens
  - Facility API keys
  - Payment method tokens

- Encryption key stored in AWS Secrets Manager
- Never hardcode encryption keys
```

Rate Limiting

Plain Text

```
- API rate limit: 1000 requests per hour per user
- Auth endpoints: 10 requests per minute per IP
- Scam analyzer: 100 requests per hour per user
- Returns 429 Too Many Requests when exceeded
```

HTTPS/TLS

```
- All API calls over HTTPS only
- TLS 1.2 or higher
- Valid SSL certificate
- HSTS header enabled
```

---

5. Error Handling

Error Response Format

```
{
  "error": {
    "code": "INVALID_EMAIL",
    "message": "Email is not valid",
    "details": "Please enter a valid email address"
  }
}
```

Common Error Codes

```
400 BAD_REQUEST - Invalid input
401 UNAUTHORIZED - Missing or invalid token
403 FORBIDDEN - User doesn't have permission
404 NOT_FOUND - Resource not found
409 CONFLICT - Resource already exists
429 TOO_MANY_REQUESTS - Rate limit exceeded
500 INTERNAL_SERVER_ERROR - Server error
503 SERVICE_UNAVAILABLE - Service temporarily unavailable
```

Error Logging

```
- All errors logged to error_logs table
- Include: user_id, error_message, error_stack, endpoint, status_code
```

```
- Admin can view errors in dashboard
- Alert on critical errors (500+)
```

---

6. Implementation Roadmap

Phase 1: Foundation (Weeks 1-2)

- Database schema and migrations
- Authentication system (signup, login, JWT)
- User profile management
- Basic settings endpoints

Phase 2: Core Features (Weeks 3-4)

- Voice assistance endpoints
- Scam detection endpoints
- Contact management
- Family management

Phase 3: Monetization (Weeks 5-6)

- Stripe billing integration
- Subscription management
- Billing webhooks
- Free tier vs. premium feature gating

Phase 4: Integrations (Weeks 7-8)

- Telecom OAuth (Verizon, AT&T, T-Mobile)
- Insurance OAuth (Medicare Advantage)
- Facility account system
- Facility billing

Phase 5: Admin & Monitoring (Weeks 9+)

- Admin endpoints
- Analytics endpoints

- Error logging and monitoring
- Admin dashboard backend

---

7. Deployment

Environment Variables

Plain Text

```
DATABASE_URL=postgresql://user:password@host:5432/seniorshield
JWT_SECRET=your-secret-key-here
JWT_EXPIRATION=24h
STRIPE_SECRET_KEY=sk_live_...
STRIPE_PUBLISHABLE_KEY=pk_live_...
OPENAI_API_KEY=sk-...
VERIZON_CLIENT_ID=...
VERIZON_CLIENT_SECRET=...
AT&T_CLIENT_ID=...
AT&T_CLIENT_SECRET=...
TMOBILE_CLIENT_ID=...
TMOBILE_CLIENT_SECRET=...
MEDICARE_CLIENT_ID=...
MEDICARE_CLIENT_SECRET=...
AWS_ACCESS_KEY_ID=...
AWS_SECRET_ACCESS_KEY=...
AWS_S3_BUCKET=seniorshield-prod
NODE_ENV=production
```

Deployment Checklist

Plain Text

```
[ ] Database migrations run successfully
[ ] All environment variables configured
[ ] SSL certificate installed
[ ] Rate limiting configured
[ ] Error logging configured
[ ] Monitoring and alerts configured
[ ] Backup strategy configured
[ ] Load balancer configured
[ ] CDN configured
[ ] Security audit passed
```

```
[ ] Performance benchmarks met
[ ] Documentation complete
```

---

8. Success Metrics

Technical Metrics

- API uptime: 99.9%
- API response time: < 500ms (p95)
- Database query time: < 100ms (p95)
- Error rate: < 0.1%

Business Metrics

- Monthly recurring revenue: $1M+
- Customer acquisition cost: < $15
- Lifetime value: > $150
- Monthly churn rate: < 3%

Summary

This backend specification includes everything needed to support your mobile app:

1. **Database** — 15 tables for all data persistence
2. **Authentication** — JWT-based user authentication
3. **API Endpoints** — 100+ endpoints for all features
4. **Billing** — Stripe integration for payments
5. **Integrations** — Telecom, Insurance, Facility OAuth flows
6. **Security** — Encryption, rate limiting, HTTPS
7. **Error Handling** — Comprehensive error logging
8. **Admin** — Endpoints for future admin panel

Timeline: 6-8 weeks for backend development

Next Step: Paste this into Replit and start building the backend API!